



Politécnico
Internacional

SEGURIDAD INFORMÁTICA

“Una máquina puede hacer el trabajo de cincuenta hombres ordinarios. Ninguna máquina puede hacer el trabajo de un hombre **extraordinario.”.**”

Elbert Hubbard

Autor

CONTENIDOS

- ☐ *Conocimientos Previos*
- ☐ *Ciberseguridad*
- ☐ *Conceptualización General*
- ☐ *Reto*



CONOCIMIENTOS PREVIOS

Antes de empezar piense en la siguiente pregunta, al finalizar la idea es tener una idea clara en su respuesta.

- *¿Qué es un riesgo?*
- *¿Qué es una amenaza?*
- *¿Qué es una vulnerabilidad?*

Hay muchas definiciones potenciales de **RIESGO**, algunas generales y otras más técnicas. Además, es importante para distinguir entre un riesgo y una amenaza. Aunque muchas personas usan las palabras amenaza y riesgo como sinónimos, tienen dos significados muy diferentes. Al igual que con cualquier concepto clave, existe alguna variación en la definición de una organización a otra



RIESGO: la combinación de la probabilidad de un evento y sus consecuencias (ISO / IEC 73). El riesgo se mitiga mediante el uso de controles o salvaguardias.



AMENAZA: cualquier cosa (por ejemplo, un objeto, una sustancia, un ser humano) que sea capaz de actuar contra un activo de una manera que puede resultar en daño. ISO / IEC 13335 define una amenaza en términos generales como una causa potencial de un incidente no deseado.

Algunas organizaciones hacen una distinción adicional entre una fuente de amenaza y un evento de amenaza, clasificando una fuente de amenaza como el proceso o agente real que intenta causar daño, y un evento de amenaza como resultado o resultado de la acción de un agente de amenaza actividad maliciosa.



ACTIVO: algo de valor tangible o intangible que vale la pena proteger, incluidas las personas, la información, infraestructura, finanzas y reputación.



VULNERABILIDAD: Una debilidad en el diseño, implementación, operación o control interno de un proceso que podría exponer el sistema a amenazas adversas de eventos de amenazas. Aunque gran parte de la ciberseguridad se centra en el diseño, implementación y gestión de controles para mitigar el riesgo, es fundamental que los profesionales de la seguridad comprendan ese riesgo nunca podrá eliminarse. Más allá de la definición general de riesgo proporcionada anteriormente, existen otras, más tipos específicos de riesgo que se aplican a la ciberseguridad.



RIESGO INHERENTE: el nivel de riesgo o exposición sin tener en cuenta las acciones que la administración ha tomado o podría tomar (por ejemplo, implementar controles)

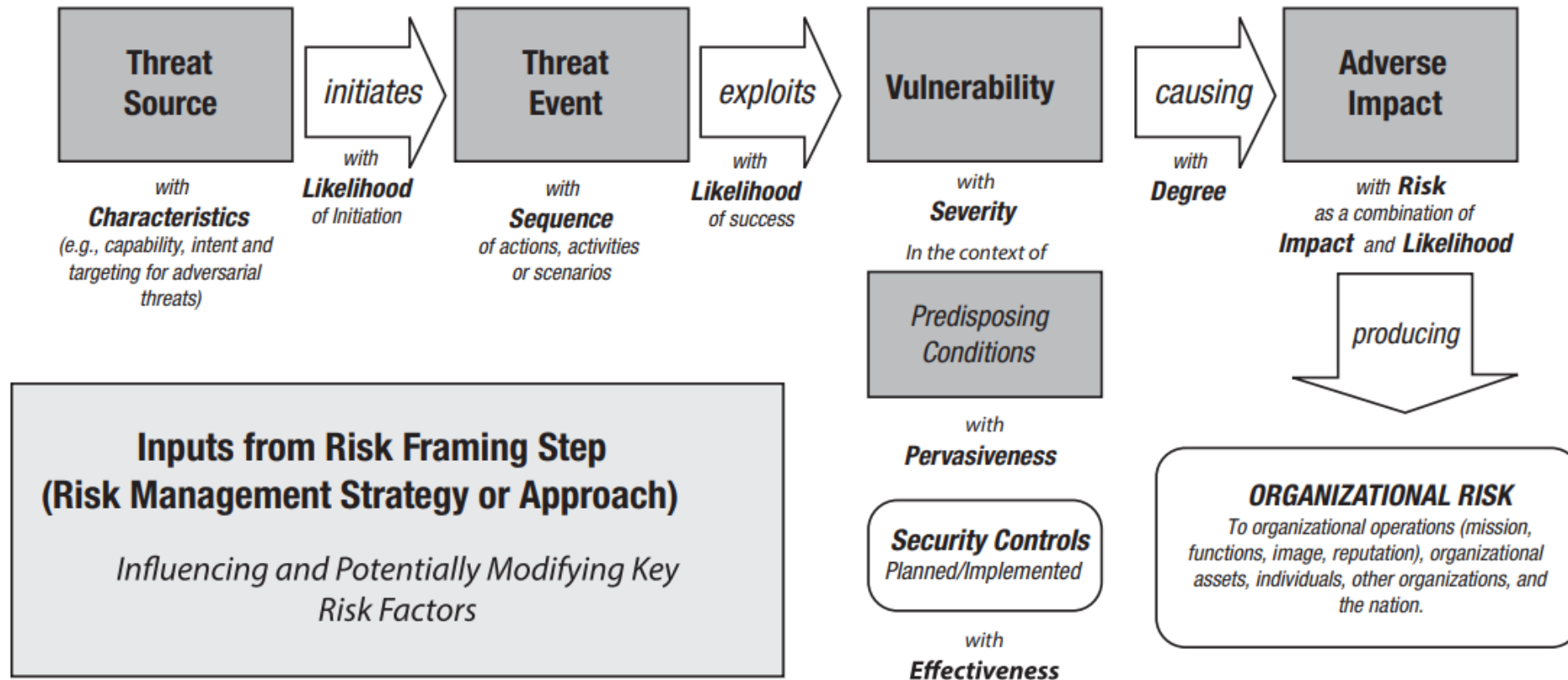


RIESGO RESIDUAL: incluso después de que se hayan implementado las salvaguardas, siempre habrá un riesgo residual, definido como el riesgo restante. Después de que la gerencia haya implementado una respuesta al riesgo.



Varias buenas fuentes para la **IDENTIFICACIÓN DE RIESGOS** y los estándares y marcos de clasificación están disponibles para el profesional en ciberseguridad. La siguiente lista no exhaustiva y hay muchos más estándares disponibles. Sin embargo, estos estándares pueden permitir al profesional de la ciberseguridad considerar un marco o estándar que sería adecuado para su uso en su organización.





Source: National Institute of Standards and Technology, "Generic Risk Model with Key Risk Factors," NIST SP 800-30, Revision 1, *Guide for Conducting Risk Assessments*, USA, Sept 2012

ISO 31000: 2009 GESTIÓN DE RIESGOS: PRINCIPIOS Y DIRECTRICES

Esta norma internacional recomienda que las organizaciones desarrollen, implementen y mejoren continuamente un marco cuyo propósito es integrar el proceso para la gestión del riesgo en la estructura general de la organización. Gobierno, estrategia y planificación, gestión, políticas de información, valores y cultura.



ISO 31000: 2009 GESTIÓN DE RIESGOS: PRINCIPIOS Y DIRECTRICES

Aunque la práctica de la gestión de riesgos se ha desarrollado a lo largo del tiempo y dentro de muchos sectores con el fin de para satisfacer diversas necesidades, la adopción de procesos consistentes dentro de un marco integral puede ayudar para garantizar que el riesgo se gestione de forma eficaz, eficiente y coherente en toda la organización. El genérico, este enfoque descrito para esta norma proporciona los principios y directrices para gestionar cualquier forma de riesgo en un de manera sistemática, transparente y creíble y dentro de cualquier ámbito y contexto



COBIT® 5 PARA RIESGO

COBIT 5 proporciona un marco integral que ayuda a las empresas a lograr sus objetivos del gobierno y la gestión de la tecnología de la información empresarial (TI). En pocas palabras, **COBIT 5** ayuda empresas para crear un valor óptimo de TI manteniendo un equilibrio entre obtener beneficios y optimizar niveles de riesgo y uso de recursos. **COBIT 5** permite que la TI sea gobernada y administrada de manera holística para el toda la empresa, teniendo en cuenta todas las áreas de responsabilidad y funciones de TI y de negocio de un extremo a otro. teniendo en cuenta los intereses relacionados con TI de las partes interesadas internas y externas. **COBIT 5 for Risk ...** se basa en el marco de **COBIT 5** al centrarse en el riesgo y proporcionar información más detallada y orientación práctica para los profesionales del riesgo y otras partes interesadas en todos los niveles de la empresa.



IEC 31010: 2009 GESTIÓN DE RIESGOS: TÉCNICAS DE EVALUACIÓN DE RIESGOS

Las organizaciones de todo tipo y tamaño se enfrentan a una serie de riesgos que pueden afectar el logro de sus objetivos.

Estos objetivos pueden relacionarse con una variedad de actividades de la organización, desde iniciativas estratégicas hasta sus operaciones, procesos y proyectos, y reflejarse en términos de seguridad social, ambiental, tecnológica y seguridad, medidas comerciales, financieras y económicas, así como sociales, culturales, políticas y impactos en la reputación.

Todas las actividades de una organización implican riesgos que deben gestionarse. El proceso de gestión de riesgos ayuda

Toma de decisiones teniendo en cuenta la incertidumbre y la posibilidad de eventos o circunstancias futuros. (intencionados o no) y sus efectos sobre los objetivos acordados

IEC 31010:2019

STANDARD

STANDARD

ISO / IEC 27001: 2013 TECNOLOGÍA DE LA INFORMACIÓN

La organización debe definir y aplicar un proceso de evaluación de riesgos de seguridad de la información que: c) identifique el riesgos de seguridad de la información:

- 1) aplicar el proceso de evaluación de riesgos de seguridad de la información para identificar los riesgos asociados con la pérdida de confidencialidad, integridad y disponibilidad de la información dentro del alcance de la seguridad de la información sistema de gestión.
- 2) identificar a los propietarios del riesgo.



ISO / IEC 27005: 2011 TECNOLOGÍA DE LA INFORMACIÓN — TÉCNICAS DE SEGURIDAD

Esta norma internacional proporciona pautas para la gestión de riesgos de seguridad de la información en una organización, apoyando en particular los requisitos de un sistema de gestión de seguridad de la información (SGSI) de acuerdo con ISO / IEC 27001. Sin embargo, esta norma no proporciona ninguna metodología específica para la seguridad de la información.

Depende de la organización definir su enfoque de la gestión de riesgos, dependiendo de ejemplo sobre el alcance del SGSI, el contexto de la gestión de riesgos o el sector industrial. Un número de existentes Las metodologías se pueden utilizar bajo el marco descrito en esta norma internacional para implementar la requisitos de un SGSI



El desarrollo de escenarios de riesgo se basa en describir un evento de riesgo potencial y documentar los factores y áreas que pueden verse afectadas por el evento de riesgo. Cada escenario debe estar relacionado con un objetivo o impacto comercial. Los eventos de riesgo pueden incluir fallas del sistema, pérdida de personal clave, robo, cortes de red, fallas de energía o cualquier otra situación que podría afectar las operaciones comerciales y la misión. La clave para desarrollar escenarios efectivos es enfocarse en eventos de riesgo potenciales reales y relevantes.



IDENTIFICACIÓN DE RIESGOS (ESCENARIOS DE RIESGO)

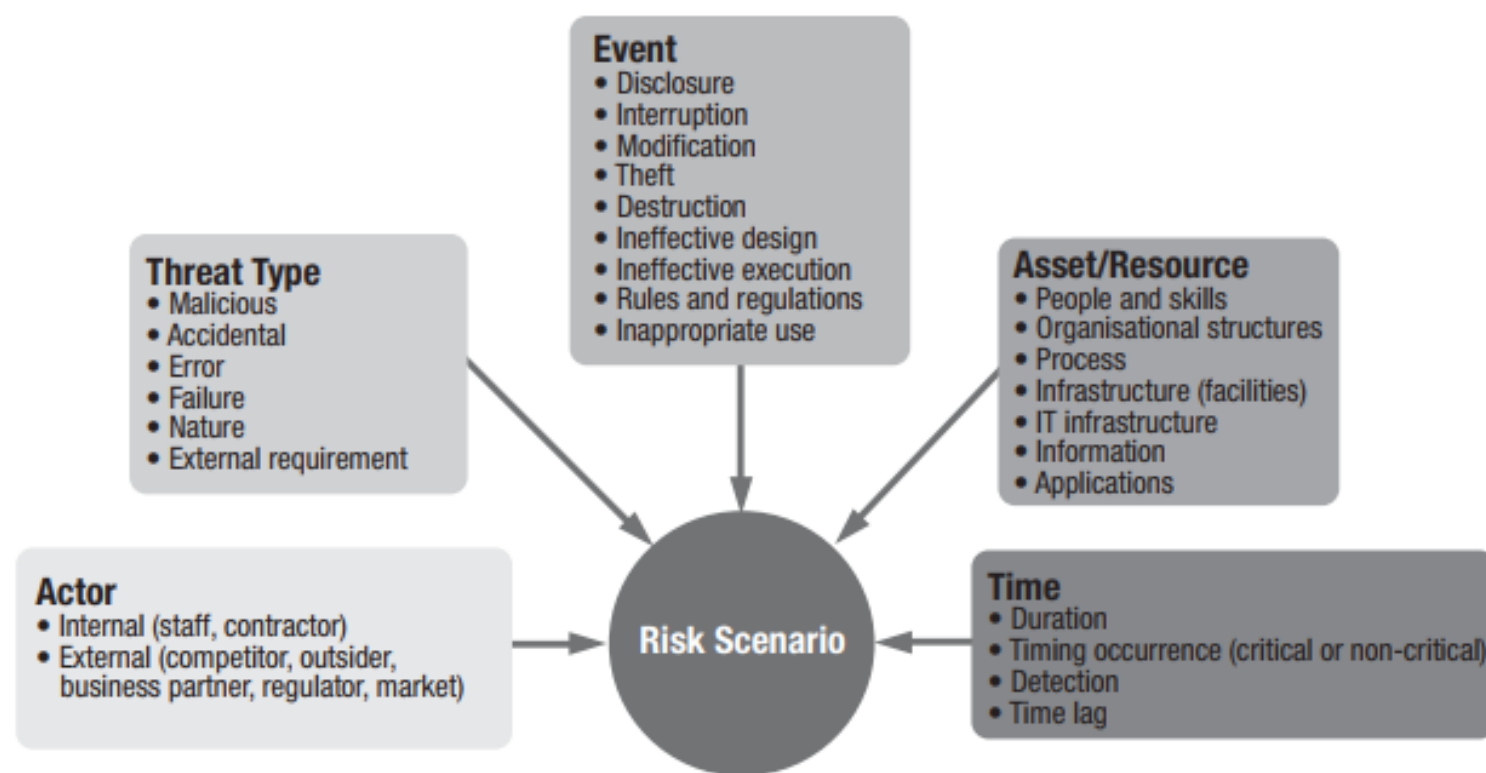
Un escenario de riesgo es una descripción de un posible evento cuya ocurrencia tendrá un impacto incierto en el logro de los objetivos de la empresa, que pueden ser positivos o negativos. El desarrollo de escenarios de riesgo proporciona una forma de conceptualizar el riesgo que puede ayudar en el proceso de identificación del riesgo. Los escenarios también se utilizan para documentar el riesgo en relación con los objetivos de negocio u operaciones impactadas por eventos, haciéndolos útiles como base, para la evaluación cuantitativa del riesgo. Cada riesgo identificado debe incluirse en uno o más escenarios, y cada escenario debe basarse en un riesgo identificado.



El desarrollo de escenarios de riesgo puramente desde la imaginación es un arte que a menudo requiere creatividad, pensamiento, consulta y cuestionamiento. Los incidentes que han ocurrido anteriormente se pueden utilizar como base de escenarios de riesgo con mucho menos esfuerzo puesto en su desarrollo. Los escenarios de riesgo basados en eventos pasados deben explorarse a fondo para garantizar que situaciones similares no se repitan de formas que podrían haberse evitado. Los escenarios de riesgo se pueden desarrollar a partir de perspectiva de arriba hacia abajo impulsada por los objetivos comerciales o desde una perspectiva de abajo hacia arriba que se origina a partir de varios insumos.



ESTRUCTURA DE UN ESCENARIO DE RIESGO



CONCLUSIONES